

Una página demasiado convincente

Marco Antonio Amaya Saucedo – 040151

CNO IV Seguridad en informática - Mtro. Servando López Contreras

Universidad Politécnica de San Luis Potosí

31 de agosto de 2026

Objetivo

Objetivo general

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Objetivos específicos

- Configurar un escenario básico de ingeniería social utilizando Social-Engineer Toolkit (SET).
- Implementar una página web ficticia mediante el módulo Credential Harvester.
- Analizar el proceso mediante el cual la información introducida en un formulario web es transmitida y registrada por un servidor.
- Identificar indicadores técnicos y visuales que permitan reconocer una página potencialmente fraudulenta.
- Proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing.

Descripción del escenario

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales.

El mensaje contiene un enlace que dirige a un portal aparentemente institucional.

La página incluye logotipo, campos de usuario y contraseña y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar."

A primera vista, nada parece fuera de lo común. Sin embargo, el portal **no pertenece a la organización**.

Configuración de laboratorio

Se usa la maquina virtual del sistema Kali Linux para hacer uso de la herramienta Social-Engineer Toolkit (SET).



```
Shell No. 1
Session Actions Edit View Help

  SET

[+] The Social-Engineer Toolkit (SET)
[+] Created by: David Kennedy (Re1k)
[+] Version: 8.0.3
[+] Codename: 'Maverick'
[+] Follow us on Twitter: @TrustedSec
[+] Follow me on Twitter: @HackingDave
[+] Homepage: https://www.trustedsec.com
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tool

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issue

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> |
```

Se crea una página web con el nombre Index.html la cual simulará un sistema institucional de autenticación con los siguientes elementos: nombre del sistema, campo de usuario, campo de contraseña, botón de ingreso, mensaje relacionado con la expiración de una sesión.



Godinez-Inc
Portal Corporativo

 Su sesión ha expirado por inactividad. Por favor, ingrese de nuevo.

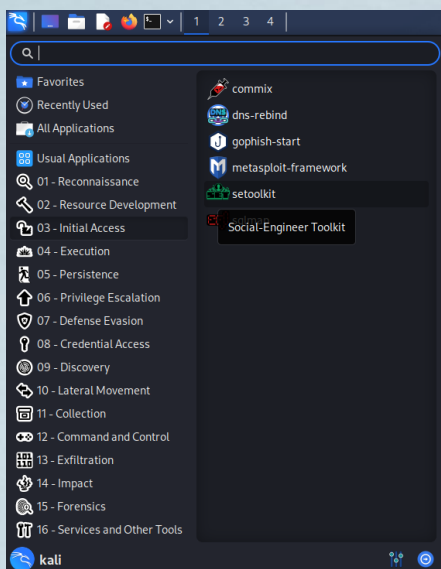
Usuario

Contraseña

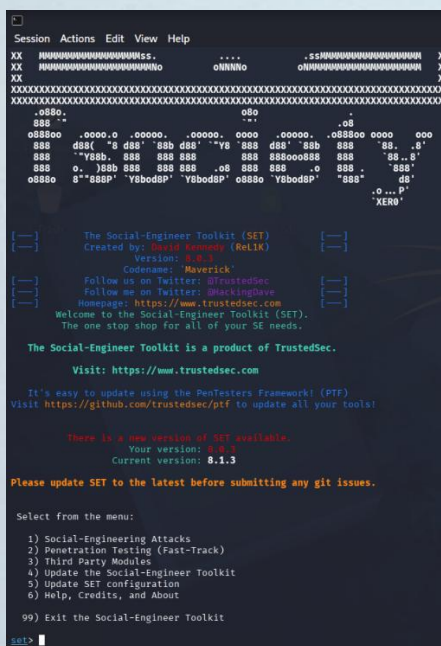
Ingresar

Implementación

En Kali Linux nos dirigimos al menú principal y en el apartado 03 – Initial Access encontraremos el acceso a setoolkit o también podemos buscarlo con este nombre en la barra de búsqueda y lo ejecutamos.



Se nos desplegará la siguiente en pantalla e ingresaremos el número **1 Social-Engineering Attacks**.



Ahora ingresaremos a la opción numero **2 Webside Attack Vectors**.

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

Ahora ingresaremos al modulo **3 Credential Harvester Attack Method**.

```
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
```

En este menú nos muestra 3 opciones de como podemos usar esta herramienta que es usando sitios web predefinido, clonando la página de un sitio y en este caso tenemos ya una página diseñada específicamente para la prueba de laboratorio escogeremos la opción **3 Custom Import**.

```
The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.
```

```
The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.
```

```
The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.
```

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

```
99) Return to Webattack Menu
```

```
set:webattack>3
```

Al momento de ingresar la opción anterior se levanta un servidor web local que nos servirá para este entorno controlado y nos dará la dirección IP del servidor que pertenece a máquina virtual Kali Linux.

```
set:webattack>3
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.0.146]:
```

Al presionar enter nos pedirá la ruta dentro de nuestro equipo de la pagina web diseñada para este laboratorio se encuentra en el escritorio.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.0.146]:
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/index.html
```

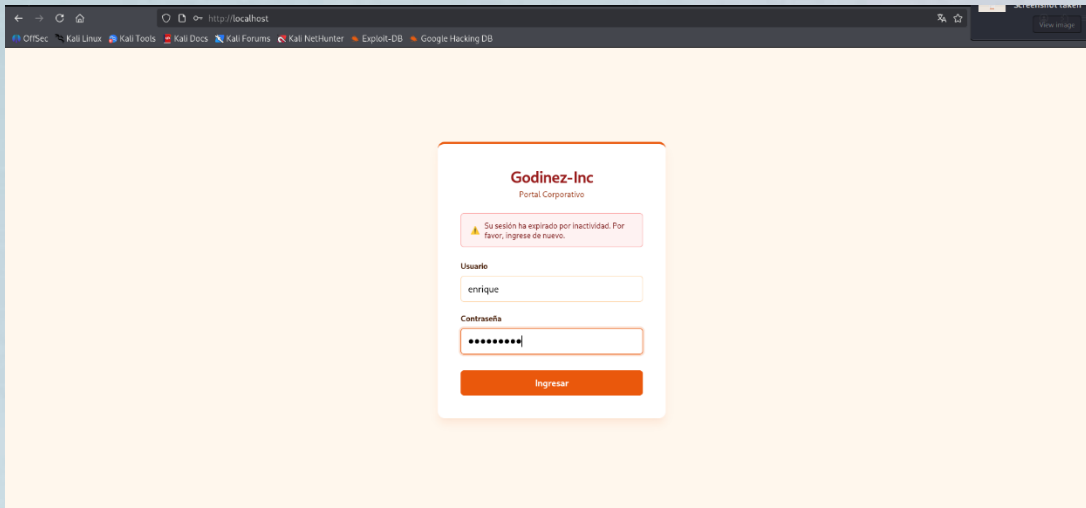
Después nos pedirá la dirección real del sitio web para que después de dar nuestros datos de acceso nos llevara a este sitio y evitar sospecha, sin embargo, como esto es ficticio ponemos la web de Google.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.0.146]:
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/index.html
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: www.google.com
```

Finalizando esto el programa se pondrá en espera de los datos sean ingresados.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```


Ingresamos a nuestro navegador e ingresamos a la dirección de servidor local localhost y nos desplegará la página web que hemos diseñado indicando que nuestra sesión expiró por lo cual debemos de ingresar nuestros datos



Después de ingresar los datos y dar clic en el botón correspondiente nos llevará al sitio configurado en pasos anteriores en este caso la página de Google.

Una vez enviado el formulario si regresamos a la terminal donde estábamos ejecutando nuestro módulo aparecerán las credenciales obtenidas en este caso el nombre de usuario **enrique** y la contraseña **P4l0m4537**.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [01/Sep/2026 00:38:07] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [01/Sep/2026 00:38:08] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=enrique
POSSIBLE PASSWORD FIELD FOUND: password=P4l0m4537
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Al finalizar nuestro módulo nos creará un reporte xml con los datos obtenidos en la siguiente ruta **/root/.set/reports/**.

```
GNU nano 9.0
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  URL=http://www.google.com
  <url>      <param>username=enrique</param>
             <param>password=P4l0m4537</param>
  </url>
</harvester>
```

Controles de seguridad propuestos

Personales

- No abrir nunca archivos adjuntos de remitentes desconocidos ni hacer clic en enlaces de fuentes sospechosas.
- Utilizar un navegador y software actualizados.
- No contestar nunca al spam.
- Evitar el uso de conexiones Wi-Fi públicas o redes inseguras.

Organizacionales

- Llevar a cabo sesiones de formación periódicas y exhaustivas sobre seguridad.
- Activar y exigir la autenticación multifactor (MFA).
- Asignar permisos adecuados a todos los usuarios y dispositivos.

Conclusión

Este tipo de ataque combinado con el descuido de los usuarios ya sea comunes o de empresas, ya sea por costumbre o desconocimiento, no se tiene el criterio para inspeccionar los sitios web de manera que nos demos cuenta que este es legítimo, el uso de este modulo me ha hecho comprender lo fácil que puede ser para un atacante hacerse de contraseñas de sistemas de empresas o contraseñas de información vital para el usuario o cuentas bancarias sin embargo implementando estas medidas propuestas para evitarlo mejora nuestra seguridad de manera significativa.